

CompTIA Security+ SY0-701 Master Cheatsheet v6

90 Qs · 90 min · Pass 750/900 · 3-6 PBQs at start · Flag & return allowed

Contents

- P1** Exam Day Rules · Domain Weights
- P2** Domain 1 — General Security Concepts (12%)
- P3** Domain 2 — Threats, Vulnerabilities, Mitigations (22%)
- P4** Domain 3 — Security Architecture (18%)
- P5** Domain 4 — Security Operations (28% — BIGGEST)
- P6** Domain 5 — Program Management & Oversight (20%)
- P7** Confusion Killer — side-by-side pairs
- P8** D4 Deep Reference
- P9** Attack → Defense Mapping
- P10** Memory Boosters — D3/D4/D5 Gap Fillers
- P11** Acronym Decoder
- P12** Wireless Auth (EAP/PEAP/TTLS/PAP)
- P13** Bluetooth & Wireless Attacks
- P14** Control Plane vs Data Plane Deep
- P15** D3/D4/D5 Last-Week Reinforcement
- P16** Port-to-Attack Quick Map
- P17** Cryptographic Attacks — Real Examples
- P18** Threat Intelligence + MITRE ATT&CK
- P19** PBQ Scenario Primer
- P20** Final Objective Gap-Fillers (Cloud/OWASP/Honey/Quantum)
- P21** 30 Power Facts + 10 Exam-Day Micro-Rules

EXAM DAY RULES

1. **Watch qualifiers:** BEST / MOST / FIRST / LEAST / NOT / EXCEPT
2. Between 2 plausible answers, pick the **more secure / more conservative** one
3. PBQs come FIRST (3-6 of them). **5-10 min MAX** per PBQ. Flag if stuck.
4. Flag & return IS allowed — use it strategically
5. ~1 min per multi-choice Q. Stuck >90 sec → flag & move on
6. Read ALL answer options — CompTIA loves plausible distractors
7. Trust first instinct. Don't change without clear reason.

Domain Weights

Domain	Weight
D1 General Security Concepts	12%
D2 Threats, Vulnerabilities, Mitigations	22%
D3 Security Architecture	18%
D4 Security Operations	28% (BIGGEST)
D5 Program Management & Oversight	20%

DOMAIN 1 — GENERAL SECURITY CONCEPTS (12%)

CIA Triad & Core Concepts

Term	Meaning
Confidentiality	Only authorized can read
Integrity	Data not altered (hashes, digital sigs)
Availability	Accessible when needed
Non-repudiation	Can't deny — via digital signatures
AAA	Authentication + Authorization + Accounting
Zero Trust	Never trust, always verify. Assume breach.

Zero Trust Architecture

Control Plane: Adaptive identity · Threat scope reduction · Policy-driven access · Policy Administrator + Policy Engine

Data Plane: Implicit trust zones · Subject/system · Policy Enforcement Point (PEP)

Security Control Types (by FUNCTION)

Type	Example
Preventive	Firewall, locks, encryption
Deterrent	Warning signs, visible cameras
Detective	IDS, logs, CCTV review
Corrective	Backup restore, patch
Compensating	Alt when primary impractical
Directive	Policy, sign

Security Control Categories

- **Technical** — tech-based (firewall, AV, encryption)
- **Managerial** — strategic (risk assessments, reviews)
- **Operational** — day-to-day (training, IR procedures)
- **Physical** — fences, guards, locks, badges

Change Management

Process: Approval · Ownership · Stakeholders · Impact analysis · Test results · Backout plan · Maintenance window · SOP

Technical: Allow/deny lists · Restricted activities · Downtime · Service restart · Legacy apps · Dependencies

Docs: Update diagrams · Update policies · Version control

Cryptography Core

Symmetric (same key, fast, bulk data)

AES (128/192/256) · **ChaCha20** · 3DES (legacy) · Blowfish/Twofish · RC4 (broken)

Asymmetric (key pair, slow, key exchange & signatures)

RSA · **ECC** (smaller keys, same strength) · **Diffie-Hellman** (key exchange) · ElGamal · DSA (signatures only)

Hashing (one-way, integrity)

SHA-256/384/512, **SHA-3** · **HMAC** (hash + secret = integrity + auth) · MD5 broken · SHA-1 deprecated

Password hashing: **bcrypt**, **scrypt**, **Argon2**, **PBKDF2** (slow = GOOD — key stretching)

Digital Signature

Sender: hash msg → encrypt hash with **sender's PRIVATE key**

Receiver: decrypt hash with **sender's PUBLIC key** → compare with own hash

Provides: Integrity + Authentication + Non-repudiation. **NOT** Confidentiality.

Encryption Direction — MEMORIZE

- **Confidentiality:** encrypt with **RECIPIENT'S PUBLIC** key
- **Signature:** encrypt hash with **SENDER'S PRIVATE** key

PKI (Public Key Infrastructure)

- **CA** — Certificate Authority (issues certs)
- **RA** — Registration Authority (verifies identity)
- **CSR** — Certificate Signing Request
- **X.509** — cert standard
- **CRL** — static list of revoked certs
- **OCSP** — real-time revocation check
- **OCSP Stapling** — server sends cached OCSP response
- **Wildcard cert** = *.example.com · **SAN cert** = multiple names
- **Key escrow** — 3rd party holds keys for recovery

Obfuscation Techniques

- **Steganography** — hide data inside other data
- **Tokenization** — replace sensitive with placeholder
- **Data masking** — replace chars with *'s

DOMAIN 2 — THREATS, VULNS, MITIGATIONS (22%)

Threat Actors

Actor	Attributes
Nation-state	External, high resources, very sophisticated, APT
Unskilled (script kiddie)	External, low resources, low skill
Hacktivist	External, moderate skill, philosophical motive
Insider threat	Internal, trusted, variable resources
Organized crime	External, high resources, financial
Shadow IT	Internal, bypasses policy

Motivations

Data exfiltration · Espionage · Service disruption · Blackmail · Financial · Philosophical/political · Ethical · Revenge · Disruption/chaos · War

Malware Types

Type	Behavior
Virus	Attaches to file; needs host + user action
Worm	Self-replicating, spreads via network
Trojan / RAT	Disguised / Remote Access backdoor
Rootkit	Kernel-level, hides deep
Keylogger / Spyware	Records keystrokes / monitors activity
Ransomware	Encrypts files, demands payment
Logic bomb	Triggers on condition
Fileless	Lives in RAM, no disk artifact
Bloatware / Cryptomalware	Preinstalled bloat / Cryptojacking

Social Engineering

Attack	What
Phishing / Spear / Whaling	Mass / Targeted / Executive
Vishing / Smishing	Voice / SMS phishing
BEC	Business Email Compromise (impersonate exec)
Pretexting	Fake scenario/story
Typosquatting	Misspelled domain (goggle.com)
Watering hole	Compromise site target visits
Pharming	DNS redirect to fake site
Impersonation / Misinformation	Pretend / Influence campaigns

Application Attacks

- **SQL Injection** — inject SQL. Defense: parameterized queries
- **XSS** — inject JS. Reflected, Stored, DOM
- **CSRF** — trick user's browser to make request
- **Buffer overflow** — overrun memory. Defense: ASLR, DEP, bounds checking
- **Race condition / TOCTOU**
- **Privilege escalation** — vertical vs horizontal
- **Replay** — capture & resend. Defense: nonces, timestamps

- **Directory traversal** — ../../../ to escape web root
- **Memory injection** — DLL injection, process hollowing

Network Attacks

- **DDoS** — volumetric · protocol (SYN flood) · app-layer (HTTP flood)
- **DNS attacks** — cache poisoning, hijacking
- **On-path (MITM)** — intercept & modify
- **ARP poisoning** — spoof ARP replies
- **Wireless:** Evil twin · Rogue AP · Deauth · Jamming · RFID cloning · Bluesnarfing

Password Attacks

- **Brute force / Dictionary**
- **Rainbow table** — precomputed hashes. Defense: **salt**
- **Password spraying** — few passwords, many accounts (evades lockout)
- **Credential stuffing** — reuse leaked creds
- **Pass-the-hash** — reuse captured NTLM hash

Cryptographic Attacks

- **Birthday / Collision** — hash collision
- **Downgrade** — force weaker protocol. Defense: disable old versions
- **Key stretching** — slow hash (bcrypt/scrypt/Argon2)

Vulnerability Types

App (memory injection, buffer overflow, race condition) · **OS / Web** · **Hardware** (firmware, EOL, legacy) · **Virtualization** (VM escape) · **Cloud** · **Supply chain** · **Mobile** (sideload, jailbreak) · **Zero-day**

DOMAIN 3 — SECURITY ARCHITECTURE (18%)

Architecture Models

- **Cloud** — Public · Private · Hybrid · Community
- **Cloud Service** — IaaS · PaaS · SaaS
- **Serverless (FaaS)** — no server management
- **Microservices** — small services via APIs
- **IoT / ICS / SCADA / RTOS / Embedded** — often legacy

Cloud Shared Responsibility

Model	Provider	Customer
IaaS	Physical, host, hypervisor, network	OS, apps, data, identity
PaaS	+ OS, runtime	Apps, data, identity
SaaS	+ Apps	Data, some identity

KEY: Customer ALWAYS responsible for data.

Network Appliances

Device	Function
Firewall (stateless / stateful)	Rules only / Tracks connection state
NGFW	Stateful + app inspection + IPS
WAF	L7 web apps (OWASP Top 10)
UTM	All-in-one (FW+IDS/IPS+AV+VPN)
IDS / IPS	Detect+alert (passive) / Detect+block (inline)
Proxy (forward / reverse)	Clients→internet / Internet→servers
Load balancer / Jump server	Distribute traffic / Hardened admin bridge
NAC	Posture check before connect

VPN & Secure Protocols

- **VPN types:** Remote access · Site-to-site · Full tunnel · Split tunnel · SSL/TLS clientless
- **IPsec:** AH (integrity) · ESP (encrypt+integrity) · Transport vs Tunnel mode · IKE (key exchange)
- **TLS 1.3** — faster (1-RTT), removed weak ciphers
- **SFTP** (SSH/22) ≠ **FTPS** (FTP+TLS/990)

Critical Ports

Port	Protocol	Port	Protocol
22	SSH/SFTP/SCP	443	HTTPS
23	Telnet (insecure)	445	SMB
25	SMTP	514	Syslog
53	DNS	636	LDAPS
69	TFTP	989/990	FTPS
80	HTTP	1433	MS SQL
88	Kerberos	1812/1813	RADIUS
123	NTP	3389	RDP
161/162	SNMP	49	TACACS+
389	LDAP	500	IKE (IPsec)

Wireless Security

Standard	Encryption	Status
WEP	RC4	Broken
WPA	TKIP	Weak
WPA2	AES/CCMP	Good
WPA3	SAE, forward secrecy	Best

Resilience & Recovery

- **HA** — no single point of failure · **Geographic redundancy**
- **Sites:** Hot (hours, live) · Warm (days, partial) · Cold (weeks, empty)
- **Power:** UPS (short) · Generator (long) · PDU
- **RAID:** 0 (stripe) · 1 (mirror) · 5 (stripe+parity) · 6 (double parity) · 10 (stripe of mirrors)
- **Backups:** Full · Incremental (since any last) · Differential (since last FULL) · Snapshot · Replication
- **3-2-1 Rule:** 3 copies, 2 media types, 1 offsite

DOMAIN 4 — SECURITY OPERATIONS (28% — BIGGEST)

Authentication Factors

Factor	Examples
Something you KNOW	Password, PIN
Something you HAVE	Smart card, token, FIDO2/YubiKey
Something you ARE	Fingerprint, retina, face
Somewhere you are	Geolocation
Something you do	Typing rhythm, gait

KEY: Strongest practical MFA = **hardware token**. Weakest = **SMS** (SIM swap).

SSO & Federation

- **SAML** — XML, enterprise SSO (SP + IdP)
- **OAuth 2.0** — AUTHORIZATION (not auth)
- **OpenID Connect (OIDC)** — auth layer on OAuth 2.0
- **Kerberos** — ticket-based, KDC, TGT, port 88
- **LDAP** = 389 · **LDAPS** = 636

Access Control Models

Model	Decision Based On
MAC	Labels/clearances (system-enforced)
DAC	Owner decides
RBAC	Job role
ABAC	Attributes of user/resource/action/env
Rule-based	If/then rules (firewall)

PAM (Privileged Access Mgmt)

- **Just-in-time permissions** — grant only when needed
- **Password vaulting** — centralized secret storage
- **Ephemeral credentials** — time-limited
- **Session recording** — admin accountability

Endpoint Security

- **EDR** — Endpoint Detection & Response
- **XDR** — Extended (endpoint+network+email+cloud correlated)
- **HIDS/HIPS** — Host-based IDS/IPS
- **DLP** — Data Loss Prevention
- **TPM** — Trusted Platform Module (per-device chip)
- **HSM** — Hardware Security Module (enterprise)
- **FDE / SED** — Full Disk Encryption / Self-Encrypting Drive
- **Measured boot / Attestation** — verify boot integrity

Vulnerability Management Process

1. **Identify** — scan, pentest, bug bounty, threat feed
2. **Analyze** — CVSS score, CVE, confirm, prioritize
3. **Respond** — Patch, Insurance, Segmentation, Compensating, Exception
4. **Validate** — Rescan, Audit, Verification, Reporting

CVSS Severity

- Critical **9.0-10.0** · High **7.0-8.9** · Medium **4.0-6.9** · Low **0.1-3.9**

Incident Response Phases

1. Preparation · 2) Detection · 3) Analysis · 4) Containment · 5) Eradication · 6) Recovery · 7) Lessons Learned

FIRST ACTION: CONTAIN per plan

Digital Forensics

- **Order of volatility (most→least):** CPU cache → RAM → Running processes/swap → Disk → Remote logs → Archive media
- **Chain of custody** — document every hand-off
- **Legal hold / E-discovery**
- **Acquisition** — forensic image, hash comparisons

Email Security

SPF (authorized senders) · **DKIM** (email signed) · **DMARC** (policy + reporting on SPF+DKIM)

DOMAIN 5 — PROGRAM MGMT & OVERSIGHT (20%)

Governance Hierarchy

- **Policies** — high-level mandatory intent (AUP, IS, BC, DR, IR, SDLC, change mgmt)
- **Standards** — mandatory specifics (password, access, encryption)
- **Procedures** — step-by-step mandatory (onboarding, playbooks)
- **Guidelines** — recommendations (not mandatory)

Risk Management

Risk Formulas

- **SLE** = Asset Value (AV) × Exposure Factor (EF)
- **ALE** = SLE × ARO (Annualized Rate of Occurrence)

Risk Responses (4)

- **Transfer** — insurance, 3rd party
- **Accept** — exemption, exception
- **Avoid** — don't do the activity
- **Mitigate** — apply controls

Business Impact Analysis (BIA)

- **RTO** — Recovery Time Objective (downtime)
- **RPO** — Recovery Point Objective (data loss in time)
- **MTTR** — Mean Time To Repair
- **MTBF** — Mean Time Between Failures

Agreement Types

Agreement	Purpose
SLA	Service Level — performance metrics
MSA	Master Service — umbrella terms
SOW	Statement of Work — specific project
MOU	Memo of Understanding — informal
MOA	Memo of Agreement — more formal
NDA	Non-Disclosure Agreement
BPA	Business Partnership Agreement

Compliance

- **HIPAA** — health · **PCI-DSS** — credit cards · **GDPR** — EU · **SOX** — US finance · **FERPA** — education · **GLBA** — finance
- **GDPR rights:** access, rectify, erase, portability, object
- **GDPR fine:** 4% global revenue OR €20M (higher)

Data Roles

Owner (accountable) · **Controller** (decides purpose) · **Processor** (acts on behalf) · **Custodian/Steward** (day-to-day)

CONFUSION KILLER — SIDE-BY-SIDE PAIRS

SAML vs OAuth vs OIDC

	SAML	OAuth 2.0	OIDC
Purpose	SSO (auth)	Authorization only	Auth on top of OAuth
Format	XML	JSON tokens	JWT
Use case	Enterprise SSO	"Allow app X access"	"Login with Google"

Trap: "Login with Google" sounds like OAuth — it's actually **OIDC**.

RADIUS vs TACACS+

	RADIUS	TACACS+
Transport	UDP 1812/1813	TCP 49
Encrypts	Password ONLY	Entire packet
Vendor	Open standard	Cisco proprietary
Use case	Network/wireless access	Device admin (routers/switches)

Symmetric vs Asymmetric — Direction

Goal	Use this key
Send confidential msg to Alice	Encrypt with Alice's PUBLIC key
Sign a message	Encrypt hash with SENDER'S PRIVATE key
Bulk data encryption	Symmetric (AES) — fast
Key exchange / signing	Asymmetric (RSA/ECC/DH) — slow

IDS vs IPS

	Position	Action
IDS	Out-of-band (passive)	Detect + alert ONLY
IPS	Inline (active)	Detect + BLOCK

Backup Types

Type	Backs up	Restore needs
Full	Everything	Last full only
Incremental	Changes since LAST backup (any)	Full + ALL incrementals
Differential	Changes since last FULL	Full + last differential

Site Types — DR

Site	Time	Has data?
Hot	Hours (live)	Real-time replicated
Warm	Days (partial)	Periodic backups
Cold	Weeks (empty)	None

Pentest Knowledge Levels

SY0-701 term	Old name	Tester knows
Known environment	White box	Everything
Partially known	Gray box	Some info
Unknown environment	Black box	Nothing

D4 DEEP REFERENCE

Identity Protocols Matrix

Protocol	Port(s)	Purpose
LDAP / LDAPS	389 / 636	Directory queries
Kerberos	88	Ticket-based auth (KDC + TGT)
RADIUS	UDP 1812/1813	AAA for network access
TACACS+	TCP 49	AAA for device admin (Cisco)
SAML / OAuth / OIDC	HTTPS 443	SSO / Authorization / Auth-on-OAuth

MFA Factor Strength

Factor	Strength
Hardware token (FIDO2/YubiKey)	Strongest — phishing-resistant
Authenticator app (TOTP)	Strong
Push notification	Medium · MFA fatigue risk
SMS	Weakest — SIM swap, NIST deprecated

Incident Response — Phase Detail

Phase	What you DO
1. Preparation	Train team · build playbooks
2. Detection	SIEM alerts · IDS/IPS
3. Analysis	Confirm · scope · root cause
4. Containment	Isolate affected systems
5. Eradication	Remove malware · patch
6. Recovery	Restore · monitor
7. Lessons Learned	Post-incident review

Trap: First action = **CONTAIN per plan**. NOT shutdown, NOT police.

ATTACK → DEFENSE INSTANT MAPPING

Attack	Best defense
SQL Injection	Parameterized queries · input validation
XSS	Input validation · output encoding · CSP
CSRF	Anti-CSRF tokens · SameSite cookies
Buffer overflow	ASLR · DEP · bounds checking
Replay attack	Nonces · timestamps
Rainbow table	Salt the hashes
Brute force / Spraying	Lockout · CAPTCHA · MFA
Pass-the-hash	Disable NTLM · LAPS · Credential Guard
Downgrade attack	Disable old protocol versions
MITM / On-path	TLS · cert pinning · VPN
ARP poisoning	Dynamic ARP Inspection
Evil twin	WPA3 · 802.1X
DNS poisoning	DNSSEC · DNS over HTTPS
DDoS	Rate limiting · CDN scrubbing
Phishing	Training · DMARC · MFA
VM escape	Patch hypervisor · isolate VMs
Supply chain	Vendor risk · SBOM · code signing
Zero-day	Defense in depth · WAF · sandboxing

MEMORY BOOSTERS — D3/D4/D5 GAP FILLERS

D5 · Risk: Analysis vs Assessment vs Management

Term	What it is
Risk Management	The whole process · identify→assess→respond→monitor
Risk Assessment	Full evaluation · what risks exist · how big · ranking
Risk Analysis	The math part · qualitative (H/M/L) or quantitative (SLE/ALE)
Risk Appetite	How much risk you'll PLAN for (expansionary/conservative/neutral)
Risk Tolerance	Acceptable VARIANCE from appetite (wiggle room)
Risk Threshold	Hard line · above this = action required

Hook: Management = whole journey · Assessment = the survey · Analysis = the math · Appetite = the plan · Tolerance = the wiggle

D5 · Audit Types

Type	Done by	Purpose
Internal audit	Your audit team	Self-check before external
External audit	3rd party (independent)	Objective verification
Regulatory audit	Government/regulator	Required by law (PCI, HIPAA)
Examination	Specific scope review	Targeted, deeper than audit
Attestation	Auditor signs declaration	Formal proof of controls

D5 · Privacy Concepts

Term	Meaning
Data minimization	Collect only what's needed
Purpose limitation	Use data only for stated reason
Right to be forgotten	GDPR · user can demand deletion
Data portability	User can export data in standard format
Pseudonymization	Replace identifiers (reversible)
Anonymization	Strip identifiers (irreversible)
DPO	Data Protection Officer (GDPR-required)

D3 · Network Security Tools

Acronym	What it is
SWG	Secure Web Gateway · proxy + URL filter + AV + DLP for OUTBOUND web traffic
WAF	Web App Firewall · protects YOUR INCOMING web apps from OWASP attacks
CASB	Cloud Access Security Broker · monitors users using SaaS (O365, Salesforce)
NAC	Network Access Control · checks posture (patches/AV) before connect
SASE	Secure Access Service Edge · cloud-delivered SD-WAN + security stack
SD-WAN	Software-defined WAN · smart routing BETWEEN sites
SDN	Software-Defined Networking · control plane separated (datacenter)
VLAN / VXLAN	L2 segmentation / VLAN extended over L3 (cloud)
ZTNA	Zero Trust Network Access · verify every request

D3 · SNMP & Monitoring

- **SNMP** — Simple Network Management Protocol · monitor devices · UDP 161/162
- **SNMPv1/v2c** = community strings (cleartext, INSECURE)
- **SNMPv3** = authentication + encryption (USE THIS)
- **Syslog** — log forwarding · UDP 514
- **NetFlow / sFlow / IPFIX** — traffic flow analysis (no payload)
- **NTP** — Network Time Protocol · UDP 123 · critical for log correlation + Kerberos

D3 · Embedded Systems & Industrial

System	What it is
SCADA	Supervisory Control And Data Acquisition · monitor large industrial
ICS	Industrial Control System · umbrella term for OT
PLC	Programmable Logic Controller · the actual machine controller
HMI	Human-Machine Interface · operator screen
RTOS	Real-Time OS · deterministic timing (cars, medical)
SoC	System on a Chip · embedded all-in-one (phones, IoT)
FPGA	Field-Programmable Gate Array · reconfigurable hardware

D4 · Hashing in Forensics

- Take forensic image → hash original → hash copy → compare
- If hashes match = bit-for-bit identical = evidence integrity proven
- **MD5** still common in forensics (collision risk acceptable, fast)
- **SHA-256** preferred for new evidence

D4 · Detection Tools

Tool	Best for
AV	Known signature malware
EDR	Behavioral analysis on endpoints · responds
XDR	Cross-source correlation
UEBA	User & Entity Behavior Analytics · anomalous user behavior
NDR	Network Detection & Response
FIM	File Integrity Monitoring · alerts on file changes

D4 · Wireless Settings

- **SSID** — network name (don't broadcast = "security through obscurity," weak)
- **BSSID** — MAC address of the access point
- **PSK** — Pre-Shared Key (WPA2/3 Personal mode)
- **Captive portal** — login page before network access (hotels)
- **Site survey** — RF analysis to plan AP placement
- **Heat map** — visual signal strength

D4 · Attack Surface Concepts

- **Attack surface** = all the ways an attacker could enter
- **Attack vector** = the specific path used (email, USB, exposed port)
- **Reduce surface:** patch · disable services · segment · least privilege
- **Threat modeling** = identify likely attack paths BEFORE (STRIDE, DREAD)

ACRONYM DECODER — EXPANDED

Network/Security Tools That Get Confused

Acronyms	What each one is
SDN vs SD-WAN vs SASE	SDN = Software-Defined Networking · separates control from data plane (DATACENTER use) · SD-WAN = Software-Defined WAN · smart routing BETWEEN sites · SASE = SD-WAN + cloud security (firewall+CASB+SWG) bundled into one cloud service
SWG vs WAF vs CASB	SWG = Secure Web Gateway · proxy + filter for users browsing OUT to web · WAF = Web App Firewall · protects YOUR web apps from incoming attacks · CASB = Cloud Access Security Broker · monitors users using cloud apps (O365, Salesforce)
SDLC vs SDL	SDLC = Software Development Life Cycle · phases: plan→design→build→test→deploy→maintain · SDL / Secure SDLC = same lifecycle WITH security at every phase ("shift left")
SAST vs DAST vs IAST	SAST = Static · scans SOURCE CODE before runtime · DAST = Dynamic · tests RUNNING app from outside (black box) · IAST = Interactive · runs INSIDE app while testing
SSO vs SOC vs SoC	SSO = Single Sign-On (auth) · SOC = Security Operations Center (the team/room) · SoC = System on a Chip (hardware)
CA vs CASB vs CAS	CA = Certificate Authority (PKI · issues certs) · CASB = Cloud Access Security Broker (cloud monitoring) · CAS = Central Authentication Service
IDS vs IDP vs IdP	IDS = Intrusion Detection System · IDP = older term for Intrusion Detection & Prevention · IdP = Identity Provider (SAML/OIDC)
RA vs RAT	RA = Registration Authority (PKI · verifies identity for CA) · RAT = Remote Access Trojan (malware backdoor)
SAML vs SAMR	SAML = Security Assertion Markup Language (SSO/XML) · SAMR = Security Account Manager Remote (Windows protocol)
SAN (storage) vs SAN (cert)	SAN storage = Storage Area Network (block storage) · SAN cert = Subject Alternative Name (multiple domains in one cert)
SIEM vs SOAR	SIEM = aggregates + correlates logs (passive analysis) · SOAR = automation + orchestration + response (action playbooks)
EDR vs XDR vs MDR vs NDR	EDR = Endpoint only · XDR = eXtended (endpoint+net+email+cloud) · MDR = Managed (outsourced 24/7 SOC) · NDR = Network only
VPN vs VLAN vs VXLAN	VPN = encrypted tunnel over public net · VLAN = L2 segmentation inside a switch · VXLAN = VLAN extended over L3 (cloud/datacenter)
NAC vs NAT	NAC = Network Access Control (posture check before allowed) · NAT = Network Address Translation (private↔public IP)
RTO vs RPO vs MTTR vs MTBF	RTO = max DOWNTIME OK · RPO = max DATA LOSS OK · MTTR = avg time to repair · MTBF = avg time between failures
BIA vs BCP vs DRP	BIA = Business Impact Analysis (find critical functions) · BCP = Business Continuity Plan (keep going during) · DRP = Disaster Recovery Plan (restore after)
HSM vs TPM	HSM = Hardware Security Module (enterprise · network-attached · multi-user keys) · TPM = Trusted Platform Module (chip on motherboard · per-device)
FDE vs SED	FDE = Full Disk Encryption (software · BitLocker, FileVault) · SED = Self-Encrypting Drive (hardware · drive does it)
MAC (access) vs MAC (address) vs HMAC	MAC access = Mandatory Access Control (labels) · MAC address = hardware NIC ID · HMAC = Hash-based Message Auth Code (integrity+auth)
UEBA vs UTM	UEBA = User & Entity Behavior Analytics (anomaly detection) · UTM = Unified Threat Management (all-in-one firewall+IDS+AV+VPN appliance)
FIM vs DLP vs CASB	FIM = File Integrity Monitoring (file changes) · DLP = Data Loss Prevention (block data exfiltration) · CASB = monitors cloud app usage

SDLC vs Secure SDLC — Phases

Phase	SDLC	Secure SDLC adds
1. Planning	Requirements gathering	+ Threat modeling (STRIDE/DREAD)
2. Design	Architecture	+ Security architecture review
3. Development	Write code	+ Secure coding standards · SAST
4. Testing	QA, bug testing	+ DAST · pen testing · code review
5. Deployment	Release to prod	+ Hardening · config baselines
6. Maintenance	Patches, updates	+ Vuln mgmt · monitoring

Hook: Same lifecycle. Just sec checks at every phase. Aka "shift left" = security earlier in the cycle.

WIRELESS AUTH PROTOCOLS — EAP / PEAP / TTLS / PAP

EAP Family (Extensible Authentication Protocol)

Type	What it does	Strength
EAP-TLS	Cert on BOTH client & server · mutual auth	Strongest (most secure WPA2/3 Enterprise)
EAP-TTLS	Cert on SERVER only · client uses password inside TLS tunnel	Strong · easier deployment than EAP-TLS
PEAP	Protected EAP · cert on server · password in tunnel · Microsoft variant	Strong · widely deployed
EAP-FAST	Flexible Auth via Secure Tunneling · uses PAC (Cisco)	Medium · Cisco-developed
EAP-MD5	Old · password hash only · no mutual auth	Weak · don't use
LEAP	Lightweight EAP · old Cisco · cracked	Broken

Memory hook: "TLS = both certs · TTLS & PEAP = server cert + tunneled password"

Old Auth Protocols (often wrong-answer distractors)

Protocol	What	Status
PAP	Password Authentication Protocol · sends password in cleartext	Broken — never use alone
CHAP	Challenge-Handshake · server sends challenge, client hashes	OK — better than PAP
MS-CHAPv2	Microsoft variant · used inside PEAP/TTLS	OK in tunnel · weak alone

WPA2/3 Modes

Mode	Auth method	Use case
WPA2/3 Personal (PSK)	Pre-Shared Key · same password for all	Home / small office
WPA2/3 Enterprise	802.1X + RADIUS + EAP · individual logins	Business · per-user accountability
WPA3 SAE	Simultaneous Authentication of Equals · replaces PSK · forward secrecy	Replaces PSK in WPA3 Personal
WPS	Wi-Fi Protected Setup · 8-digit PIN · BROKEN	Disable · easy to brute force

BLUETOOTH & WIRELESS ATTACKS

Bluetooth Attacks

Attack	What happens
Bluejacking	Send unsolicited messages to nearby Bluetooth devices · annoying, low harm
Bluesnarfing	Steal data (contacts, messages, files) from victim's device
Bluebugging	Take CONTROL of device · make calls, read texts, eavesdrop
Bluesmacking	DoS attack · flood device with oversized packets
Car whisperer	Inject audio to/from Bluetooth car kits with default PIN
BlueBorne	2017 vulnerability · code execution without pairing

Hook: jacking = junk msgs · snarfing = stealing data · bugging = full control · smacking = DoS

Wi-Fi Recon & Attack Names

Term	Meaning
War driving	Driving around to map open/weak Wi-Fi networks
War flying	Same as war driving but with drone
War walking	On foot version
War chalking	Marking sidewalks/walls with symbols showing nearby Wi-Fi info (old)
Evil twin	Rogue AP that mimics legitimate SSID · steals creds
Rogue AP	Unauthorized AP on the network (any kind)
Deauth attack	Forge deauth frames to kick clients off · forces reconnect (often to evil twin)
Jamming	RF interference · denial of service for wireless
Disassociation	Similar to deauth · disconnects clients from AP
KRACK	Key Reinstallation Attack · WPA2 vulnerability (patched)

RFID / NFC Attacks

- **RFID cloning** — copy an RFID badge to a blank card
- **NFC skimming** — eavesdrop NFC payment from a few cm away
- **Relay attack** — extend the range of a key fob (car theft via signal relay)

CONTROL PLANE vs DATA PLANE — DEEP

The Core Idea

Networking and Zero Trust both split into two planes: a **brain** that decides, and a **muscle** that does. Knowing which is which is heavily tested in D3 and D1 (Zero Trust).

	Control Plane (the brain)	Data Plane (the muscle)
Function	Decides WHAT to do	Actually moves the traffic
Speed	Slower · processing decisions	Fast · forwarding packets
Examples (networking)	Routing protocols (OSPF, BGP) · ARP tables · MAC tables	Packet forwarding · switching · ASICs
Examples (Zero Trust)	Policy Engine · Policy Administrator · Adaptive identity	Policy Enforcement Point (PEP) · Subject/system · Resources
Examples (SDN)	SDN Controller (centralized brain)	Switches/routers just forward as told

Concrete Example — Zero Trust Login Flow

1. User tries to access app · request hits the **PEP (data plane)**
2. PEP asks the **Policy Engine (control plane)**: "Should I allow this?"
3. Policy Engine checks user identity, device health, location, time, risk score
4. Decision sent back: ALLOW or DENY
5. PEP enforces the decision · traffic flows or is blocked

Concrete Example — SDN

- **Traditional network:** each router/switch makes its own routing decisions (control + data plane on same box)
- **SDN:** central controller (control plane) tells switches (data plane only) where to forward packets
- Result: programmable, faster changes, easier to manage at scale

Why This Matters on the Exam

Trap question: "Which is part of the Zero Trust control plane?" Answers like "Policy Engine" or "Policy Administrator" → control plane. Answers like "PEP" or "user accessing resource" → data plane.

D3/D4/D5 LAST-WEEK REINFORCEMENT

D3 · Switch Security (STP family + BPDU)

Term	What it is
STP	Spanning Tree Protocol · prevents L2 loops by blocking redundant paths · slow convergence (30-50s)
RSTP	Rapid STP · same idea but converges in seconds · current default
BPDU	Bridge Protocol Data Unit · the messages STP/RSTP use to elect root bridge & map paths
BPDU attack	Attacker sends fake BPDUs · forces own device to be root bridge · MITM all switch traffic
BPDU Guard	Defense · disables port if it receives a BPDU on user-facing access ports
Root Guard	Prevents specific port from becoming root · keeps STP topology stable
MAC flooding	Fill switch CAM table · forces switch to flood like a hub · enables sniffing
Port security	Limits MAC addresses per port · defense vs MAC flooding/spoofing
DHCP snooping	Switch only allows DHCP replies from trusted ports · stops rogue DHCP servers
Dynamic ARP Inspection (DAI)	Validates ARP packets against DHCP snooping table · stops ARP poisoning

Switch defenses combo: Port Security + DHCP Snooping + DAI + BPDU Guard = locked-down access ports

D3 · DNS Records You Must Know

Record	Maps	Use
A	Name → IPv4	Most common
AAAA	Name → IPv6	"quad-A"
CNAME	Alias → another name	www.example.com → example.com
MX	Mail exchange	Where to deliver email
NS	Name server	Authoritative DNS for zone
TXT	Text data	SPF, DKIM, DMARC records live here
PTR	IP → name (REVERSE lookup)	Anti-spam · email server identity verification
SOA	Start of Authority	Zone admin info, refresh times
SRV	Service location	Where to find AD/SIP/etc services
DNSKEY / RRSIG / DS	DNSSEC records	Sign & verify DNS data

PTR trap: "PTR record" answer = REVERSE DNS lookup. Email servers check PTR matches sending IP — failure = spam classification.

D3 · IPv6 Quick Notes

- **128-bit addresses** · 8 groups of 4 hex digits
- No NAT needed (huge address space)
- **Link-local** = fe80::/10 (auto-configured per interface)
- **Loopback** = ::1 (vs IPv4 127.0.0.1)
- **Unspecified** = ::
- **NDP** (Neighbor Discovery Protocol) replaces ARP · vulnerable to NDP spoofing
- IPsec was originally mandatory in IPv6 spec (now optional)

D4 · Group Policy & Windows Hardening

Term	What
GPO	Group Policy Object · Windows centralized config (passwords, software, settings)
LAPS	Local Admin Password Solution · randomizes local admin passwords across endpoints · prevents pass-the-hash spread
UAC	User Account Control · prompts for elevation before privileged action
AppLocker / WDAC	Windows app whitelisting · blocks unauthorized executables
Credential Guard	Isolates credentials in virtualized container · stops pass-the-hash
BitLocker	Microsoft FDE · uses TPM for key storage
Secure Boot	UEFI feature · only runs OS loaders signed by trusted keys
Measured Boot	Logs each boot stage to TPM · attestation proves chain not tampered

D4 · MDM & Mobile Security

- **MDM** = Mobile Device Management · enroll, configure, wipe corporate data
- **UEM** = Unified Endpoint Mgmt · MDM + laptop/desktop together
- **BYOD** · **COPE** (Corp-Owned Personally Enabled) · **CYOD** (Choose Your Own) · **Corporate-owned**
- **Containerization** = separate work data from personal on device
- **Geofencing** = restrict device function based on location
- **Remote wipe** · **Screen lock** · **Push notification policies**
- **Sideload** = install apps outside official store · risk vector
- **Jailbreak (iOS)** / **Root (Android)** = bypass OS restrictions · MDM should detect

D4 · Logging Sources Reminder

Log	Tells you
Firewall	Allowed/denied connections, ports, IPs
Application	App errors, transactions, user actions
OS / Security	Logins, privilege use, audit events (Windows Event Log)
IDS/IPS	Detected attack signatures, blocked actions
Endpoint	Process execution, file changes, EDR alerts
Authentication	Login success/fail, MFA challenges, lockouts
Vuln scan	CVEs found, severity, affected hosts
NetFlow / sFlow	Traffic flows, bandwidth, talkers (no payload)
DNS	Queries, responses · spot beaconing & DGA malware
Web server	Access logs, errors, attacks (e.g., 4xx/5xx surges)

D4 · Common SIEM Use Cases (exam scenarios)

- **Failed logins spike** → brute force / password spraying
- **Login from impossible location** (geo-velocity) → compromised account
- **Off-hours admin activity** → insider or compromised admin
- **Large outbound data transfer** → data exfiltration / DLP needed
- **Repeated DNS queries to weird domains** → C2 beaconing
- **Multiple AV detections same host** → infected endpoint, isolate

D5 · Awareness Training Topics (commonly listed on exam)

- Phishing campaigns / simulations
- Anomalous behavior recognition
- User guidance & training
- Reporting (how to report suspicious activity)

- Insider threat indicators
- Password management
- Removable media / cables
- Social engineering (vishing, smishing, BEC)
- OPSEC (Operational Security · don't post sensitive info publicly)
- Hybrid / remote work risks
- AUP (Acceptable Use Policy)
- Situational awareness

D5 · Policy Documents Hierarchy (exact terms)

Doc	What it says	Mandatory?
Policy	"WHAT" — high-level intent (we will protect data)	Yes
Standard	"HOW MUCH" — specific requirements (passwords ≥14 chars)	Yes
Procedure	"HOW" — step-by-step instructions (onboarding playbook)	Yes
Guideline	"SUGGESTED" — best practice recommendations	No
Baseline	Minimum security config (CIS/STIG/SCAP)	Yes (when adopted)

D5 · Specific Policies the Exam Names

- **AUP** — Acceptable Use Policy
- **IS / Information Security Policy** — overall sec posture
- **BCP / DR / IR plans** — continuity / recovery / response
- **SDLC policy** — how software is built/maintained
- **Change Management policy** — approval, backout, docs
- **Onboarding / Offboarding** — provision/deprovision access
- **Playbooks** — step-by-step IR runbooks (SOAR uses these)

D5 · External Frameworks (recognize them)

Framework	What it's for
NIST CSF	Cybersecurity Framework · Identify-Protect-Detect-Respond-Recover
NIST RMF	Risk Management Framework · 7 steps for federal systems
NIST SP 800-53	Security & privacy controls catalog (federal)
ISO 27001	Info Security Management System · international standard
ISO 27002	Code of practice · controls reference for 27001
ISO 27701	Privacy extension to 27001
CIS Controls	18 prioritized controls · most-used baseline
PCI-DSS	Payment card industry · 12 requirements
CSA CCM	Cloud Security Alliance · Cloud Controls Matrix
MITRE ATT&CK	Adversary tactics & techniques · threat modeling

PORT-TO-ATTACK QUICK MAP

If a Q mentions a port, the attack is usually one of these. Memorize the pairings.

Port	Service	Common attack	Defense
20/21	FTP	Cleartext credential sniffing	Use SFTP (22) or FTPS (990)
22	SSH	Brute force, weak keys	Key auth · disable password · fail2ban
23	Telnet	Cleartext sniffing	NEVER use · replace with SSH
25	SMTP	Open relay, spam	Auth required · SPF/DKIM/DMARC
53	DNS	Cache poisoning · tunneling · DDoS amp	DNSSEC · DoH/DoT
80	HTTP	MITM, sniffing, injection	Force HTTPS · HSTS
88	Kerberos	Pass-the-ticket · Golden Ticket · Kerberoasting	Strong service account pwds · monitor TGT
110/143	POP3 / IMAP	Cleartext credentials	POP3S 995 · IMAPS 993
123	NTP	DDoS amplification · time skew breaks Kerberos	Restrict NTP responders
161/162	SNMP	Community string brute force (v1/v2c)	SNMPv3 only
389	LDAP	Cleartext bind · injection	LDAPS 636 · LDAP injection filtering
443	HTTPS	SSL strip · weak cipher · cert spoofing	HSTS · TLS 1.3 · cert pinning
445	SMB	EternalBlue · lateral movement · ransomware spread	Disable SMBv1 · segmentation
514	Syslog	UDP spoofed log injection	TLS-secured syslog · TCP 6514
3389	RDP	BlueKeep · credential stuffing · ransomware	VPN-only · NLA · MFA · patch
1433	MS SQL	SQL injection · brute force	Network segmentation · least privilege

CRYPTOGRAPHIC ATTACKS — REAL EXAMPLES

Attack	What happens	Real example / hook	Defense
Birthday	Find two inputs producing same hash	"23 people in a room — 50% chance 2 share birthday" — used to forge digital sigs against MD5	Use SHA-256+ · longer hash
Collision	Same as birthday but more general	MD5 collisions allowed fake CA certs (2008)	Drop MD5 · drop SHA-1
Downgrade	Force protocol to older/weaker version	POODLE attack forced TLS to SSL 3.0	Disable old versions · enforce TLS 1.2+
Brute force	Try every key	DES 56-bit cracked in days	Use AES 128/256 · longer keys
Known plaintext	Have plaintext + ciphertext, derive key	WW2 Enigma broken partly this way	Modern ciphers resist this
Replay	Capture & resend valid encrypted message	Capture login cookie, replay later	Nonces · timestamps · session tokens
Side channel	Extract key via timing, power, EM emissions	Spectre / Meltdown · power analysis on smart cards	Constant-time crypto · shielding
Implementation	Bug in crypto code, not the algorithm	Heartbleed (OpenSSL bug) leaked memory	Patch · fuzzing · audited libraries

THREAT INTELLIGENCE

Core Terms

Term	Meaning	Hook
TTPs	Tactics, Techniques, Procedures · how attackers operate	Tactics = goal · Techniques = method · Procedures = exact tool/step
IoC	Indicator of Compromise · evidence attack ALREADY happened	Hashes, IPs, domains, file names · "smoke after fire"
IoA	Indicator of Attack · evidence attack is HAPPENING NOW	Behavior patterns · "smoke during fire"
STIX	Structured Threat Information eXpression · format for sharing intel	The LANGUAGE
TAXII	Trusted Automated eXchange of Intelligence Information · transport protocol	The DELIVERY TRUCK
OSINT	Open Source Intelligence · public sources (news, social, leaks)	Free recon
Threat hunting	Proactively search for threats BEFORE alerts fire	Don't wait for SIEM to scream
Threat feed	Subscription stream of fresh IoCs	Updates your blocklists/SIEM rules
Dark web monitoring	Watch underground forums for leaked creds, mentions of your org	Early warning
SBOM	Software Bill of Materials · inventory of all components in software	Defense vs supply chain attacks (Log4j)

MITRE ATT&CK Matrix Layout (commonly tested)

Columns = **Tactics** (the goal at each stage). Rows under each column = **Techniques**. Stage order:

1. Reconnaissance
2. Resource Development
3. Initial Access
4. Execution
5. Persistence
6. Privilege Escalation
7. Defense Evasion
8. Credential Access
9. Discovery
0. Lateral Movement
1. Collection
2. C2 (Command & Control)
3. Exfiltration
4. Impact

Hook: ATT&CK = post-exploitation focus · Cyber Kill Chain (Lockheed) = pre-exploitation focus (recon → weaponize → deliver → exploit → install → C2 → actions)

PBQ SCENARIO PRIMER — WHAT TO EXPECT

5 Common PBQ Types

1. Firewall Rule Configuration

- Drag-drop or fill-in: source IP · dest IP · port · action (allow/deny)
- **Strategy:** Most-specific rules at top · default deny at bottom
- **Watch for:** "implicit deny" assumption · stateful vs stateless

2. Log Analysis

- Read several log entries · identify the attack
- **Watch for:** failed logins → brute force · multiple users from one IP → spraying · unusual times → insider
- **Strategy:** match log pattern to attack from D2

3. Network Diagram Hardening

- Click to place WAF, IDS, firewall, DMZ in correct spot on diagram
- **Strategy:** WAF in front of web servers · IDS spans traffic · DMZ between internet & internal · jump server before sensitive segments

4. Attack Identification (drag & drop)

- Match scenario description → attack name
- **Strategy:** use Attack→Defense table on P9 · the tells:
 - "user got fake email" = phishing
 - "DNS redirects to attacker site" = pharming/poisoning
 - "many failed logins one user" = brute force
 - "few passwords many users" = spraying

5. Wireless / VPN Configuration

- Pick correct EAP type · protocol · cipher
- **Strategy:** WPA3 > WPA2-Ent > WPA2-PSK · EAP-TLS for max security · TLS 1.3 over old SSL

PBQ Tactics That Save Time

1. **Read FULL scenario before clicking anything**
2. **Easy parts first** · skip hard sub-questions, return
3. **Partial credit exists** — do what you know
4. **5-10 min HARD MAX** per PBQ · flag if stuck
5. **Come back later** with fresh eyes after MC done

FINAL OBJECTIVE GAP-FILLERS

Cloud Concepts (often missed)

Term	Meaning
VPC	Virtual Private Cloud · isolated cloud network
Security group	Stateful virtual firewall on cloud instances (AWS/Azure)
NACL	Network ACL · stateless cloud network filter
API gateway	Manages, secures, throttles API calls to cloud services
Container	Lightweight isolation (Docker) · shares host kernel
Container escape	Break out of container to host · patch & restrict capabilities
Right to audit clause	Contractual right to inspect cloud provider
Resource policies	Define who/what can access cloud resources (IAM-like)

Hashing Use Cases (don't confuse)

Use case	Algorithm
File integrity	SHA-256, SHA-512
Password storage	bcrypt, scrypt, Argon2, PBKDF2 (slow on purpose)
Forensic image verification	MD5 / SHA-256 (speed matters · collision risk acceptable)
HMAC for message auth	HMAC-SHA-256
Digital signature	SHA-256 + RSA/ECDSA

OWASP Top 10 (2021) — Headlines

1. Broken Access Control
2. Cryptographic Failures
3. Injection (SQL, OS, LDAP)
4. Insecure Design
5. Security Misconfiguration
6. Vulnerable & Outdated Components
7. Identification & Authentication Failures
8. Software & Data Integrity Failures
9. Security Logging & Monitoring Failures
0. Server-Side Request Forgery (SSRF)

Honey Stuff (decoys)

Term	What
Honeypot	Fake system to lure attackers · gather TTPs
Honeynet	Network of honeypots
Honeyfile	Decoy file (e.g., "passwords.xlsx") · access = alert
Honeytoken	Decoy credential / data string · use = alert
DNS sinkhole	Redirect malicious domain queries to your safe server · breaks malware C2

Code Signing & Software Integrity

- **Code signing** = developer signs binary with private key · users verify with public key
- Verifies source + integrity (not tampered after signing)
- Defense vs supply chain attacks · also for OS updates & mobile apps

Quantum & Post-Quantum (be ready)

- Quantum computers will break RSA & ECC eventually (Shor's algorithm)

- **Post-quantum cryptography** = new algorithms resistant to quantum (NIST is selecting)
- **Symmetric (AES-256) is mostly safe** — just double key sizes
- **Quantum key distribution (QKD)** = uses quantum physics for unbreakable key exchange

30 POWER FACTS + 10 EXAM-DAY MICRO-RULES

30 Power Facts

1. **Format:** 90 Qs / 90 min / Pass 750/900 · 3-6 PBQs at start · Flag & return allowed
2. **Control TYPES:** Preventive/Deterrent/Detective/Corrective/Compensating/Directive
3. **Control CATEGORIES:** Technical/Managerial/Operational/Physical
4. **Zero Trust:** Control plane (policy engine + admin) / Data plane (PEP + subject)
5. **CIA + Non-repudiation + AAA**
6. **SLE** = AV × EF · **ALE** = SLE × ARO
7. **4 risk responses:** Transfer · Accept · Avoid · Mitigate
8. **Symmetric:** AES, ChaCha20 · **Asymmetric:** RSA, ECC, DH · **Hash:** SHA-256, HMAC · **Password:** bcrypt/scrypt/Argon2
9. **Digital signature:** hash + encrypt with **SENDER'S PRIVATE** key
0. **Confidentiality encryption:** use **RECIPIENT'S PUBLIC** key
1. **CVSS:** Crit 9+ · High 7-8.9 · Med 4-6.9 · Low 0.1-3.9
2. **IR phases:** Prep → Detection → Analysis → Containment → Eradication → Recovery → Lessons
3. **Order of volatility:** CPU cache → RAM → disk → remote logs → archives
4. **SAML** = SSO (XML) · **OAuth** = authz · **OIDC** = auth on OAuth
5. **Kerberos:** KDC, TGT, port 88
6. **RADIUS** (UDP 1812/13) vs **TACACS+** (TCP 49, Cisco)
7. **802.1X + EAP-TLS** = strongest wireless auth
8. **WPA2** = AES/CCMP · **WPA3** = SAE
9. **IPsec:** AH (integrity) · ESP (encrypt+integrity) · Tunnel vs Transport
0. **SFTP** (SSH/22) ≠ **FTPS** (FTP+TLS/990)
1. **BIA:** RTO = downtime · RPO = data loss · MTTR = repair · MTBF = between failures
2. **Threat actors:** Nation-state (APT) · Hacktivist · Insider · Organized crime · Unskilled · Shadow IT
3. **Agreements:** SLA · MSA · SOW · MOU · NDA · BPA
4. **Password attacks:** Brute · Dictionary · Rainbow (salt) · Spraying · Stuffing · Pass-the-hash
5. **IDS** = alert only · **IPS** = block
6. **Cloud responsibility:** IaaS customer = OS+apps+data · SaaS customer = data only
7. **IR First Action:** CONTAIN per plan
8. **Data roles:** Owner · Controller · Processor · Custodian
9. **SPF / DKIM / DMARC** = email authentication trio
0. **PBQ strategy:** Read full scenario · 5-10 min MAX · flag & return if stuck

10 Exam-Day Micro-Rules

1. **BEST/MOST/FIRST/EXCEPT/NOT** — circle them mentally
2. Stuck between 2 answers? Pick **more secure / more conservative**
3. "What's the FIRST step?" in IR = **CONTAIN** (per plan)
4. "Most volatile?" = **CPU cache / RAM**, never disk
5. "Strongest auth?" = **hardware token + something else**
6. "User got phishing email" = answer involves **training + technical control** together
7. "Detect" wants IDS/SIEM/EDR · "Block/prevent" wants IPS/firewall/WAF
8. Cloud question? — **customer always owns DATA** regardless of model
9. "Confidentiality" = encrypt with recipient's PUBLIC · "Integrity proof" = digital signature (private key)
0. PBQ stuck > 8 min? **Flag and move on.** Do MC first, return after.